SOC AUTONOMOUS LAB

Technical Blueprint & Master Execution Specification

Objetivo: construir um laboratório SOC reproduzível na Oracle Cloud, usando agentes de IA para apoiar planejamento, provisionamento, configuração, validação e documentação.

Item	Definição
Cloud	Oracle Cloud Infrastructure (OCI)
Região pretendida	Brazil East — São Paulo
Orquestração	DeepSeek Harness (DSH)
Agente de desenvolvimento	OpenCode, quando aplicável
Infraestrutura como código	Terraform + OCI CLI
Stack de segurança	Wazuh, Elastic Security, Sysmon, Zeek e Suricata
Ambiente local	Acer com Windows 11
Crédito informado	Aproximadamente R$ 1.100 restantes; saldo, elegibilidade e expiração devem ser verificados na console
Versão	1.0 — 02/11/2026

Princípio de operação: autonomia para inspecionar, planejar, gerar código e validar; aprovação humana obrigatória antes de ações pagas, destrutivas ou que alterem a exposição de rede e permissões.

Documento preparado para ser fornecido ao DeepSeek Harness como especificação inicial do projeto. Não contém credenciais, chaves privadas ou autorização para provisionamento automático.

1. Visão geral e objetivos

O projeto deverá entregar um laboratório de operações de segurança (SOC) com telemetria realista, dois ambientes SIEM, simulações controladas e investigações documentadas. O foco é demonstrar competências práticas compatíveis com atividades de SOC N2 e Detection Engineering.

- Construir infraestrutura reproduzível e versionada na Oracle Cloud.
- Implantar Wazuh como primeira plataforma SIEM/XDR.
- Implantar Elastic Security como segunda plataforma para comparação de ingestão, regras e investigação.
- Monitorar um endpoint Windows 11 usando Wazuh Agent e Sysmon.
- Adicionar monitoramento de rede com Zeek e Suricata quando houver orçamento e topologia adequada.
- Executar simulações controladas e documentar evidências, linha do tempo, análise e recomendações.
- Usar agentes de IA para acelerar tarefas sem remover o controle humano sobre a tenancy.

2. Arquitetura lógica

Camadas do ambiente:

Camada	Componentes	Responsabilidade
AI orchestration	DeepSeek Harness, perfis/agentes e OpenCode	Planejar, delegar, gerar código, revisar e relatar
Cloud infrastructure	OCI, Terraform, OCI CLI, Ubuntu	Rede, VMs, volumes, acesso e configuração base
Security monitoring	Wazuh, Elastic Security, Sysmon	Coleta, normalização, detecção, alertas e investigação
Network monitoring	Zeek, Suricata	Metadados de rede, DNS, HTTP e alertas de tráfego
Simulation	Kali ou Linux de testes, ferramentas controladas	Gerar eventos benignos e simulações autorizadas

Fluxo de alto nível:

Windows 11 / máquinas de teste → agentes e coletores → Wazuh e/ou Elastic → alertas e eventos → investigação → relatórios em investigations/. O agente de IA administra a preparação e a automação por meio de ferramentas explicitamente autorizadas.

3. Infraestrutura-alvo na Oracle Cloud

Região pretendida: Brazil East (São Paulo). O agente deverá verificar o identificador de região efetivamente configurado na tenancy, disponibilidade de shapes, quotas, limites de Free Trial e preços antes de criar qualquer recurso.

Componente	Alvo inicial	Uso	Prioridade
SOC-WAZUH-01	Ubuntu 24.04; 4 OCPUs; 8 GB RAM; 50 GB	Wazuh all-in-one	P1 — primeiro SIEM
SOC-ELASTIC-01	Ubuntu 24.04; 4 OCPUs; 32 GB RAM; 100 GB	Elasticsearch, Kibana e Elastic Security	P2 — após Wazuh
SOC-ATTACK-01	Linux/Kali; 2 OCPUs; 4 GB RAM; 50 GB	Simulações controladas, sob demanda	P3 — temporário

Componente	Alvo inicial	Uso	Prioridade
SOC-NETWORK-01	Ubuntu; 2 OCPUs; 8 GB RAM; 50 GB	Zeek e Suricata	P4 — opcional

Os tamanhos acima são referências de dimensionamento, não uma autorização de compra. O Harness deve apresentar alternativas menores e uma estimativa de custo por hora/mês. Deve considerar armazenamento, IPs públicos, tráfego, snapshots, backups, volumes e demais encargos. Não presumir que o crédito promocional cobre todos os serviços.

Estratégia de orçamento

- Verificar saldo e data/hora exatos de expiração no painel de billing; o valor informado pelo proprietário é aproximado.
- Priorizar Wazuh e endpoint. Não provisionar simultaneamente todas as VMs sem análise de custo.
- Manter Elastic e máquinas de simulação desligadas ou não provisionadas até a etapa correspondente, considerando que discos, IPs e outros recursos podem continuar cobrando mesmo com a VM parada.
- Criar alertas de orçamento e registrar custos observados após cada etapa.
- Não fazer upgrade de conta nem contratar serviços pagos recorrentes sem autorização explícita.

4. Rede e controles de segurança

- Criar uma VCN dedicada ao SOC Lab, após inventário dos recursos existentes.
- Separar sub-redes públicas e privadas quando tecnicamente viável.
- Preferir acesso administrativo por VPN ou túnel SSH; dashboards SIEM devem permanecer privados.
- Restringir SSH à origem administrativa autorizada e usar chaves SSH, nunca senha compartilhada.
- Não expor Elasticsearch (9200), Wazuh API (55000) ou interfaces administrativas diretamente à internet.
- Restringir comunicação dos agentes e coletores às origens e destinos necessários.
- Documentar cada regra de NSG/Security List e justificar sua necessidade.
- Não alterar regras de rede, IAM ou recursos preexistentes sem aprovação.

Portas devem ser determinadas a partir das versões e topologia efetivamente implantadas. Não copiar listas de portas sem verificar a documentação oficial da versão selecionada.

5. Stack de segurança

Tecnologia	Papel	Validação obrigatória
Wazuh	Manager, Indexer, Dashboard e agentes; FIM, vulnerabilidades, eventos e alertas	Compatibilidade de versão, sizing, serviços ativos, ingestão e alertas de teste
Elastic Security	Elasticsearch, Kibana, ingestão e detecções	Licenciamento, recursos disponíveis, sizing e ingestão real
Sysmon	Telemetria de processos, conexões e eventos de sistema Windows	Configuração, Event Channels e eventos realmente coletados
Zeek	Metadados e análise de protocolos de rede	Fonte de tráfego, interface espelhada/visível e logs gerados
Suricata	IDS/NSM e alertas de tráfego	Interface, regras, EVE JSON e alertas de teste

A instalação deve usar versões estáveis suportadas e instruções oficiais atuais. O agente não deve misturar comandos de versões diferentes nem assumir que todos os recursos do Elastic estão disponíveis gratuitamente.

6. Casos de uso e detecções

ID	Cenário	Fonte de telemetria
SOC-001	Múltiplas falhas de autenticação / brute force controlado	Windows Security Events / Wazuh
SOC-002	Execução suspeita de PowerShell em ambiente de teste	Sysmon / Windows Event Logs
SOC-003	Modificação de arquivo monitorado	Wazuh FIM
SOC-004	Anomalia ou consulta DNS de teste	Zeek / Sysmon
SOC-005	Varredura de portas em alvo próprio	Suricata / Zeek
SOC-006	Criação e execução de processo de teste	Sysmon
SOC-007	Requisições HTTP de teste contra aplicação local/lab	Logs HTTP / sensor
SOC-008	Detecção de vulnerabilidades	Wazuh Vulnerability Detection

Mapear detecções aplicáveis ao MITRE ATT&CK.; Quando fizer sentido, manter regras Sigma portáveis e traduzir para formatos específicos (por exemplo, SPL, KQL ou EQL). Nunca afirmar que uma regra funciona sem validar contra telemetria real.

7. Padrão de documentação de incidentes

- ID e título do incidente.
- Resumo executivo e severidade estimada.
- Escopo e ativos envolvidos.
- Linha do tempo com timestamps e fuso horário.
- Eventos, consultas e evidências reproduzíveis.
- Passos de investigação e hipóteses consideradas.
- Mapeamento MITRE ATT&CK;, quando aplicável.
- Avaliação de impacto e possibilidade de falso positivo.
- Conclusão, recomendações e ações de contenção propostas.
- Referências a regras, dashboards e arquivos de evidência.

8. Arquitetura e responsabilidades dos agentes

Agente / papel	Responsabilidades	Limites
Orchestrator — DSH	Interpretar a missão, dividir tarefas, coordenar perfis, consolidar relatórios e solicitar aprovações	Não contornar políticas de aprovação nem executar ações proibidas
Infrastructure Engineer	Inventário OCI, Terraform, VCN, compute, volumes, estimativa de custos	Não aplicar Terraform nem alterar recursos sem aprovação
SOC Engineer	Instalação e configuração de Wazuh, Elastic e agentes	Não expor serviços nem armazenar segredos no repositório
Detection Engineer	Regras, Sigma, SPL, KQL, EQL, cenários de detecção	Testes apenas em ativos e ambientes autorizados
Validation Engineer	Testes, revisão de segurança, health checks e documentação	Relatar falhas; não desativar controles para fazer testes passarem
OpenCode	Implementação de código, scripts, arquivos e automações conforme delegação	Integração com DSH deve ser verificada; não presumir comunicação automática

Os papéis podem ser perfis especializados usando o mesmo modelo DeepSeek. Não é necessário contratar quatro modelos diferentes. O Harness deve verificar a integração real com OpenCode e documentar o mecanismo de delegação, entradas, saídas e permissões.

9. Segurança, identidade e aprovação humana

Criar identidade dedicada para o laboratório, com permissões mínimas. Preferir grupo IAM e políticas limitadas ao compartment do SOC Lab. Não utilizar a identidade administrativa principal para automação.

- Credenciais OCI e chaves privadas devem ficar fora do Git e fora dos prompts.
- Não imprimir tokens, chaves, arquivos de configuração sensíveis ou segredos nos logs.
- Não enviar credenciais a serviços de terceiros ou modelos.
- Acesso de leitura para inventário pode ser automatizado após configuração segura.
- Aprovação explícita obrigatória para criar recursos que gerem cobrança, aumentar shape, criar armazenamento pago ou alocar IP pago.
- Aprovação explícita obrigatória para alterar IAM, VCN, NSG, Security Lists ou regras de firewall.
- Aprovação explícita obrigatória para terraform apply, destroy, exclusão ou alteração destrutiva.
- Operações de leitura, geração de arquivos no workspace e validações locais podem ser automatizadas dentro do sandbox.
- Não usar modo de acesso irrestrito ou permissões administrativas globais.

Matriz de autorização

Operação	Política
Consultar inventário e estado de recursos	Permitido após autenticação de leitura
Criar/editar arquivos do projeto	Permitido no workspace controlado
Executar terraform fmt/validate/plan	Permitido; revisar resultados
Executar terraform apply	Aprovação explícita do proprietário
Criar compute, volumes ou IPs pagos	Aprovação explícita após estimativa de custo

Operação	Política
Alterar IAM ou regras de rede	Aprovação explícita e revisão de segurança
Excluir ou destruir recursos	Bloqueado por padrão; aprovação específica obrigatória

10. Estrutura do repositório

```
soc-autonomous-lab/
■■■ README.md
■■■ AGENTS.md
■■■ PROJECT_SPEC.md
■■■ infrastructure/terraform/ (providers, networking, compute, security, variables)
■■■ infrastructure/scripts/
■■■ infrastructure/inventory/
■■■ wazuh/ (manager, agents, rules, configuration)
■■■ elastic/ (configuration, integrations, detection-rules)
■■■ endpoint/ (sysmon, windows-agent)
■■■ network/ (zeek, suricata)
■■■ simulations/ (brute-force, powershell, network-scanning)
■■■ detections/ (sigma, spl, kql, eql)
■■■ investigations/ (SOC-001, SOC-002, SOC-003)
■■■ docs/ (architecture, deployment, troubleshooting)
```

Regras de repositório:

- Não versionar arquivos de credenciais, chaves, tokens, terraform.tfstate ou arquivos .tfvars sensíveis.
- Fornecer .gitignore e exemplos .env.example sem valores secretos.
- Fixar versões de providers e ferramentas quando apropriado.
- Documentar comandos de instalação, atualização, validação e recuperação.
- Usar commits pequenos e mensagens que descrevam mudanças.

11. Workflow obrigatório por fases

Fase	Nome	Entregáveis / critério de conclusão
01	Discovery	Verificar ferramentas locais, tenancy, região, compartment, recursos, quotas, custos e data de expiração. Somente leitura.
02	Design	Diagrama, inventário, alternativas de sizing, estimativa de custos e plano de segurança.
03	Repository	Estrutura, README, AGENTS.md, especificação, .gitignore e documentação inicial.
04	Infrastructure	Terraform format/validate/plan. Revisão humana antes de qualquer apply.
05	Wazuh	Instalação e health checks; dashboard privado; evidência de ingestão.
06	Endpoint	Windows Agent e Sysmon conectados; eventos validados.
07	Elastic	Elastic Security implantado e recebendo telemetria; licenciamento verificado.
08	Network	Zeek/Suricata instalados somente se houver fonte de tráfego adequada e orçamento.
09	Detections	Casos de uso, regras e testes com eventos reais de laboratório.
10	Investigations	Três ou mais relatórios de investigação completos.
11	Final review	Revisão de segurança, custos, documentação, recuperação e reprodutibilidade.

12. Relatório obrigatório ao final de cada fase

- Resumo da fase e tarefas concluídas.
- Recursos consultados, criados ou modificados (com identificadores não sensíveis).
- Comandos executados e arquivos alterados.
- Resultados de validação e evidências.
- Falhas, riscos e pendências.
- Custo estimado e custo observado, quando disponível.
- Próxima ação proposta e aprovação necessária.

13. Critérios de sucesso

- Infraestrutura documentada e reproduzível.
- Wazuh operacional e recebendo eventos do endpoint Windows.
- Sysmon coletando eventos relevantes.
- Elastic Security operacional e recebendo telemetria, se orçamento e licença permitirem.
- Pelo menos três casos de uso de detecção validados.
- Pelo menos três investigações documentadas com evidências.
- Dashboards e APIs administrativas não expostos publicamente.
- Nenhuma credencial ou segredo armazenado no Git.
- Custos e recursos da Oracle documentados; plano de desligamento/remoção revisado pelo proprietário.

14. MASTER PROMPT — Instruções para o DeepSeek Harness

Copie o bloco abaixo e forneça ao Harness como missão inicial. O PDF inteiro serve como especificação de referência; o texto a seguir define a primeira execução.

```
ROLE: You are the lead AI infrastructure engineer for the SOC Autonomous Lab.

MISSION: Plan, deploy, configure, validate and document a reproducible SOC Home Lab on Oracle Cloud
Infrastructure (OCI), using DeepSeek Harness, OpenCode where appropriate, Terraform and OCI CLI.

PROJECT OWNER CONTEXT: The owner is learning cloud infrastructure automation and cybersecurity engineering.
Explain unfamiliar operations and provide concise, technically accurate guidance. Do not assume prior
knowledge.

CLOUD CONTEXT:
- Provider: Oracle Cloud Infrastructure.
- Intended region: Brazil East (São Paulo); verify actual region identifier.
- Account type: Free Trial.
- Promotional credit: approximately BRL 1,100 remaining, unverified.
- Expiration: November 2026, exact date/time unknown; verify in the console.

TARGET STACK:
- Wazuh all-in-one as the first SIEM.
- Elastic Security as the second SIEM, subject to sizing and licensing validation.
- Windows 11 endpoint with Wazuh Agent and Sysmon.
- Zeek and Suricata as optional network sensors.
- Controlled attack simulations and documented incident investigations.
- Terraform for infrastructure as code.

AGENT ROLES:
1. Orchestrator: plan, delegate, consolidate and request approvals.
2. Infrastructure Engineer: OCI inventory, Terraform, network, compute and cost estimation.
3. SOC Engineer: Wazuh, Elastic, endpoint and telemetry configuration.
4. Detection Engineer: Sigma, SPL, KQL, EQL and test cases.
5. Validation Engineer: health checks, security review and documentation.

INTEGRATION REQUIREMENT: Do not assume DSH and OpenCode are automatically integrated. Inspect installed
versions and available integration mechanisms first. Document the verified delegation method before relying on
it.

MANDATORY SAFETY RULES:
- Begin with read-only discovery. Do not create, modify or delete cloud resources during the first phase.
- Never run terraform apply or destroy without explicit owner approval.
- Never create billable resources without presenting an itemized estimate and obtaining explicit approval.
- Never change IAM, network security rules or firewall exposure without approval.
- Never expose SIEM dashboards, Elasticsearch port 9200 or Wazuh API port 55000 publicly.
- Never store credentials, API keys, private keys or tokens in Git or project prompts.
- Use a dedicated least-privilege OCI identity, not the owner's administrative identity.
- Never delete or modify pre-existing resources without explicit, resource-specific approval.
- Do not enable unrestricted agent or shell access.
- If a requested action cannot be performed safely, stop and explain why.

REQUIRED PHASES:
1. Discovery: inspect local tools and OCI tenancy using read-only access.
2. Design: architecture, network plan, sizing alternatives and itemized cost estimate.
3. Repository: create project structure, README, AGENTS.md and .gitignore.
4. Infrastructure: generate Terraform; run fmt, validate and plan; wait for approval.
5. Wazuh: deploy and validate after approval.
6. Endpoint: connect Windows 11 and configure Sysmon.
7. Elastic: deploy and validate after sizing/licensing approval.
8. Network: add Zeek/Suricata only if technically feasible and approved.
9. Detections: implement and test controlled use cases.
10. Investigations: create at least three evidence-backed reports.
11. Final review: security, costs, documentation, reproducibility and shutdown plan.

REPORTING: At the end of every phase, report completed tasks, commands, files changed, resources
inspected/modified, validation results, issues, cost estimate and the next approval required.

FIRST TASK — PHASE 1 DISCOVERY:
Inspect the local Windows environment and determine whether Node.js, npm, Git, WSL2, OpenCode, Terraform and
OCI CLI are available. Do not install software without explaining the change and asking for approval if
administrative privileges or system changes are required.

Then, if OCI read-only credentials are already safely configured, inspect tenancy resources, compartments,
region, compute instances, VCNs, subnets, volumes, public IPs, quotas, budgets and cost information. Do not
print secrets. If access is not configured, explain the least-privilege setup needed; do not ask the owner to
paste credentials into chat.
```

```
OUTPUT: Produce a discovery report with (a) local tool inventory, (b) OCI resource inventory, (c) quota and
availability findings, (d) credit/expiration findings or explicit unknowns, (e) security observations, (f)
recommended architecture and cost estimate, and (g) approval requests.

STOP after the discovery report. Do not provision, modify, upgrade or delete anything until the owner
explicitly approves the next phase.
```

15. Referências oficiais

- Oracle Cloud Infrastructure CLI
- OCI Identity and Access Management
- Terraform Documentation
- Wazuh Documentation
- Elastic Security Documentation
- Microsoft Sysmon
- Zeek Documentation
- Suricata Documentation
- OpenCode Documentation

Nota final: este blueprint é uma especificação de projeto, não uma confirmação de preços, disponibilidade de shapes ou elegibilidade de serviços na conta Oracle. O Harness deve verificar os dados atuais na tenancy e nas documentações oficiais antes de propor qualquer implantação.